

[KAN-11] Sistem tidak memiliki mekanisme lockout atau rate limiting untuk mencegah brute force attack pada halaman Login

Created: 03/Dec/25 Updated: 03/Dec/25

Status:	To Do
Project:	Practice Software Testing QA
Components:	None
Affects versions:	None
Fix versions:	None

Type:	Bug	Priority:	Highest
Reporter:	Erlina Febiola Nainggolan	Assignee:	Unassigned
Resolution:	Unresolved	Votes:	0
Labels:	brute_force_attack, security		
Remaining Estimate:	Not Specified		
Time Spent:	Not Specified		
Original estimate:	Not Specified		

Attachments:	 SEC-007_Tidak Ada Brute Force Protection pada Login.png
Rank:	0ji0003b:

Description

User dapat melakukan percobaan login berkali-kali tanpa adanya pembatasan, baik berupa account lockout, captcha, maupun delay. Ini memungkinkan attacker untuk melakukan brute force attack menggunakan automated tools.

Steps to Reproduce:

1. Buka halaman Login
2. Input email yang valid
3. Coba password yang salah sebanyak 5–10 kali berturut-turut
4. Tidak ada mekanisme lockout atau captcha yang muncul
5. User masih bisa terus mencoba login

Expected Result:

- Setelah 3–5 percobaan gagal, sistem harus:
 - Mengunci akun sementara (misal 15 menit), atau
 - Menampilkan CAPTCHA, atau
 - Menerapkan progressive delay
- Error message tidak boleh spesifik (misal: "email tidak terdaftar" atau "password salah")

Actual Result: Tidak ada pembatasan apapun, user dapat terus melakukan percobaan login tanpa henti